MITRE ATLAS | AML.CS0023 - ShadowRay

Entry Information

ID:
AML.CS0023
Type:
Case-Study
Name:
ShadowRay
URL:
https://atlas.mitre.org/studies/AML.CS0023/
Incident Date:
2023-09-05
Target:
Multiple systems
Actor:
Ray

Description

Ray is an open-source Python framework for scaling production AI workflows. Ray's Job API allows for arbitrary remote execution by design. However, it does not offer authentication, and the default configuration may expose the cluster to the internet. Researchers at Oligo discovered that Ray clusters have been actively exploited for at least seven months. Adversaries can use victim organization's compute power and steal valuable information. The researchers estimate the value of the compromised machines to be nearly 1 billion USD.

Five vulnerabilities in Ray were reported to Anyscale, the maintainers of Ray. Anyscale promptly fixed four of the five vulnerabilities. However, the fifth vulnerability [CVE-2023-48022](https://nvd.nist.gov/vuln/detail/CVE-2023-48022) remains disputed. Anyscale maintains that Ray's lack of authentication is a design decision, and that Ray is meant to be deployed in a safe network environment. The Oligo researchers deem this a "shadow vulnerability" because in disputed status, the CVE does not show up in static scans.

Attack Procedure:
[AML.T0006] Active Scanning: Adversaries can scan for public IP addresses to identify those potentially hosting Ray dashboards. Ray dashboards, by default, run on all network interfaces, which can expose them to the public internet if no other protective mechanisms are in place on the system.
[AML.T0049] Exploit Public-Facing Application: Once open Ray clusters have been identified, adversaries could use the Jobs API to invoke jobs onto accessible clusters. The Jobs API does not support any kind of authorization, so anyone with network access to the cluster can execute arbitrary code remotely.
[AML.T0035] AI Artifact Collection: Adversaries could collect AI artifacts including production models and data.

The researchers observed running production workloads from several organizations from a variety of industries.
[AML.T0055] Unsecured Credentials: The attackers could collect unsecured credentials stored in the

cluster.

The researchers observed SSH keys, OpenAI tokens, HuggingFace tokens, Stripe tokens, cloud environment keys (AWS, GCP, Azure, Lambda Labs), Kubernetes secrets.
[AML.T0025] Exfiltration via Cyber Means: AI artifacts, credentials, and other valuable information can be exfiltrated via cyber means.

The researchers found evidence of reverse shells on vulnerable clusters. They can be used to maintain persistence, continue to run arbitrary code, and exfiltrate.
[AML.T0010.003] Model: HuggingFace tokens could allow the adversary to replace the victim organization's models with malicious variants.
[AML.T0048.000] Financial Harm: Adversaries can cause financial harm to the victim organization. Exfiltrated credentials could be used to deplete credits or drain accounts. The GPU cloud resources themselves are costly. The researchers found evidence of cryptocurrency miners on vulnerable Ray clusters.

References

- ShadowRay: First Known Attack Campaign Targeting AI Workloads Actively Exploited In The Wild — https://www.oligo.security/blog/shadowray-attack-ai-workloads-actively-exploited-in-the-wild

- ShadowRay: AI Infrastructure Is Being Exploited In the Wild — https://protectai.com/threat-research/shadowray-ai-infrastructure-is-being-exploited-in-the-wild

- CVE-2023-48022 — https://nvd.nist.gov/vuln/detail/CVE-2023-48022

- Anyscale Update on CVEs — https://www.anyscale.com/blog/update-on-ray-cves-cve-2023-6019-cve-2023-6020-cve-2023-6021-cve-2023-48022-cve-2023-48023